



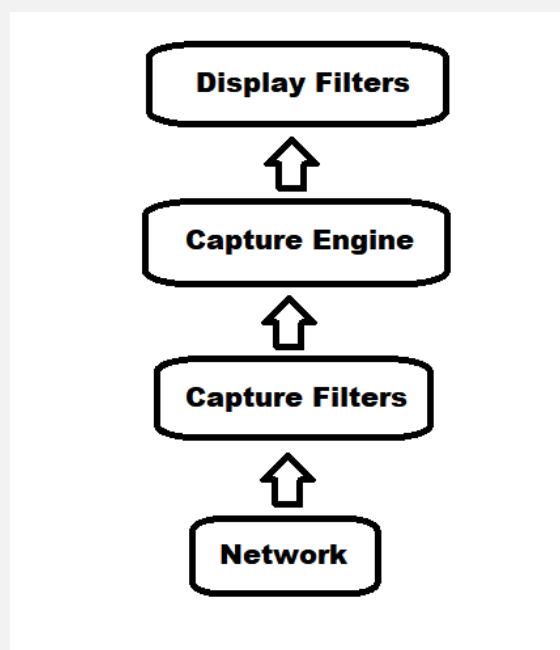
АКАДЕМИЯ
КОДЕБАЙ

ПРОФЕССИЯ ПЕНТЕСТЕР



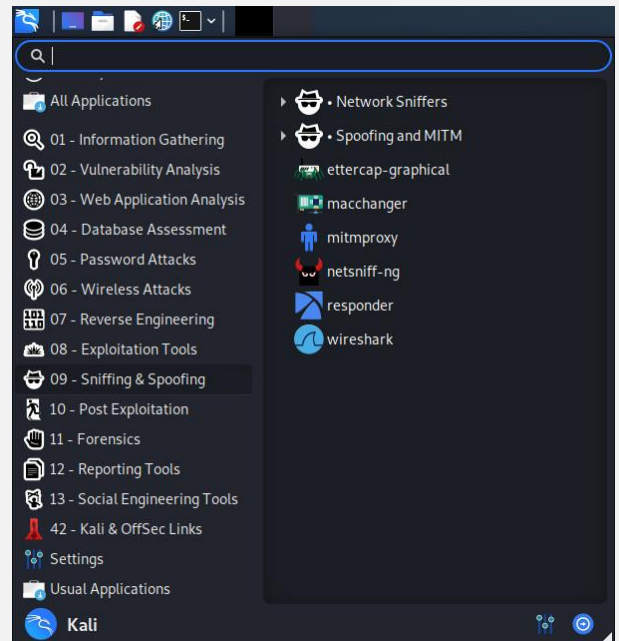
Компетентный пентестер должен хорошо разбираться в основах сетевых технологий. Сетевой сниффер Wireshark является обязательным инструментом для изучения сетевых протоколов, анализа сетевого трафика и отладки сетевых служб. В этом разделе мы обсудим некоторые основы работы с Wireshark.

Wireshark использует библиотеки Libpcap (в Linux) или Winpcap (в Windows) для захвата пакетов из сети. Анализируя сетевой трафик с помощью сниффера, легко запутаться в количестве так называемого "шума" в собранных данных. Чтобы облегчить анализ, можно применить capture filters и display filters в Wireshark. Если мы применим фильтры во время сеанса Wireshark, все пакеты, которые не соответствуют критериям фильтра, будут отброшены, а оставшиеся данные будут переданы механизму захвата (capture engine). Затем механизм захвата разбирает входящие пакеты, анализирует их и применяет дополнительные фильтры отображения перед выводом на экран:



Секрет использования любого сетевого сниффера, включая Wireshark, заключается в том, чтобы научиться использовать фильтры захвата и фильтры отображения для удаления лишних данных. К счастью, графический интерфейс Wireshark делает это и позволяет относительно легко визуализировать данные и работать с различными фильтрами.

В следующем примере мы будем захватывать сетевой трафик во время анонимного входа по FTP. На нашей системе Kali мы запускаем Wireshark с помощью командной строки (`sudo wireshark`), или через меню приложений, в подменю Sniffing & Spoofing.

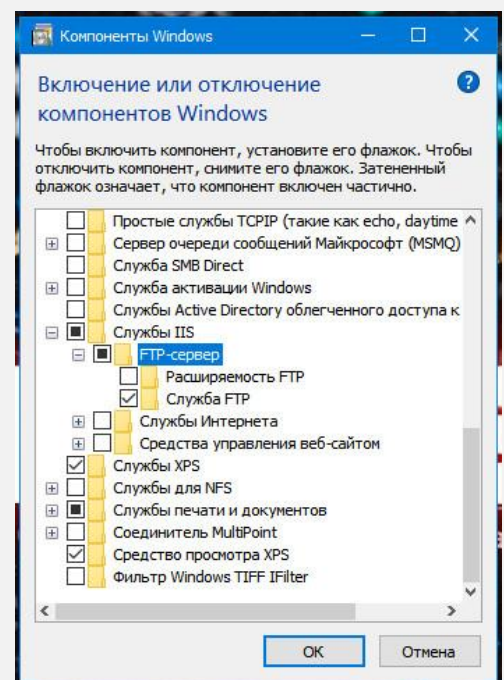


P.S. Для начала настройте FTP-сервер на основной машине под управлением Windows:

1. Нажать «Пуск» и открыть раздел «Панель управления». Для удобства просмотра можно выбрать режим «Мелкие значки».

2. Перейти в раздел «Программы и компоненты», где выбрать «Включение или отключение компонентов Windows».

3. В списке открывшегося меню нужно отметить компоненты, которые следует активировать, поставив рядом галочку. Это папка «FTP-сервер», в ней два пункта: «Расширяемость FTP» и «Служба FTP», а также папка «Средства управления веб-сайтом», а в ней — «Консоль управления IIS». Для запуска нажать ОК.



Настройка:

1. Теперь нужно снова зайти через «Пуск» в «Панель управления».
2. Найти раздел «Администрирование» и открыть в этом разделе «Диспетчер служб IIS».
3. Перейти во вкладку «Сайты», щёлкнув на название правой кнопкой, выбрать из списка «Добавить FTP сайты».
4. В новом окне требуется указать имя будущего FTP-сервера, и путь к каталогу с его данными. К следующему этапу настройки можно перейти, нажав кнопку «Далее».
5. Теперь устанавливаются параметры сервера. В поле IP-адреса выбрать нужный из списка. Можно привязать его к определённому адресу или сделать расширенный доступ, выбрав пункт «Все свободные».
6. В новом окне задаётся тип авторизации. В пункте «Проверка подлинности» можно разрешить вход для обычных или анонимных пользователей. Здесь же можно настроить для них права. Нажать «Готово».

Теперь обязательно необходимо настроить брандмауэр Windows для открытия портов и функционирования служб.

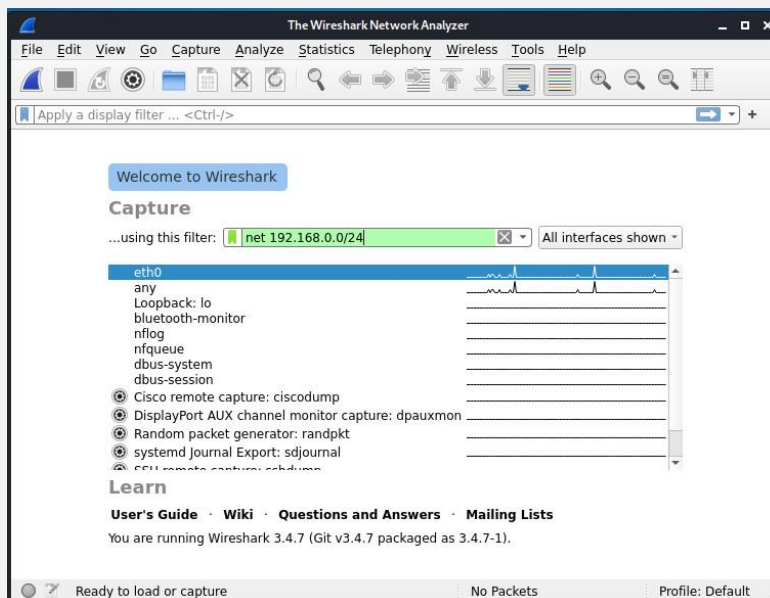
Снова войти в «Панель управления», затем «Брандмауэр Windows». Найти раздел «Дополнительные параметры».

В нём выбрать «Правила для входящих соединений». Для них рекомендуется установить пассивный режим. Для этого правой кнопкой мыши нажать и включить правила «Трафик FTP-сервера в пассивном режиме» и «FTP-сервер (входящий трафик)». Таким же образом для исходящих подключений включить в соответствующем разделе правило «FTP-сервер».

Фильтры захвата

Когда Wireshark загружается, перед нами появляется окно, в котором мы можем выбрать сетевой интерфейс, который мы хотим контролировать, а также установить фильтры отображения и захвата. Мы можем использовать фильтры захвата, чтобы уменьшить количество перехваченного трафика, отбрасывая любой трафик, который не соответствует нашему фильтру, и сфокусироваться на пакетах, которые мы хотим проанализировать. Имейте в

виду, что любой трафик, исключенный из фильтра захвата, будет потерян, поэтому лучше всего определять широкие фильтры захвата, если вы обеспокоены потенциальной потерей данных. Начнем с выбора интерфейса, который мы хотим контролировать, и ввода фильтра перехвата. В данном примере я буду использовать фильтр `net`, чтобы перехватывать трафик только в диапазоне адресов `192.168.0.0/24`:



Также можно выбрать один из predefined фильтров захвата, перейдя в меню `Capture > Capture filters`, а также можно добавить собственные фильтры захвата, нажав на знак `+`. Установив фильтр захвата мы можем начать захват, дважды щелкнув на нашем сетевом интерфейсе из списка доступных интерфейсов.

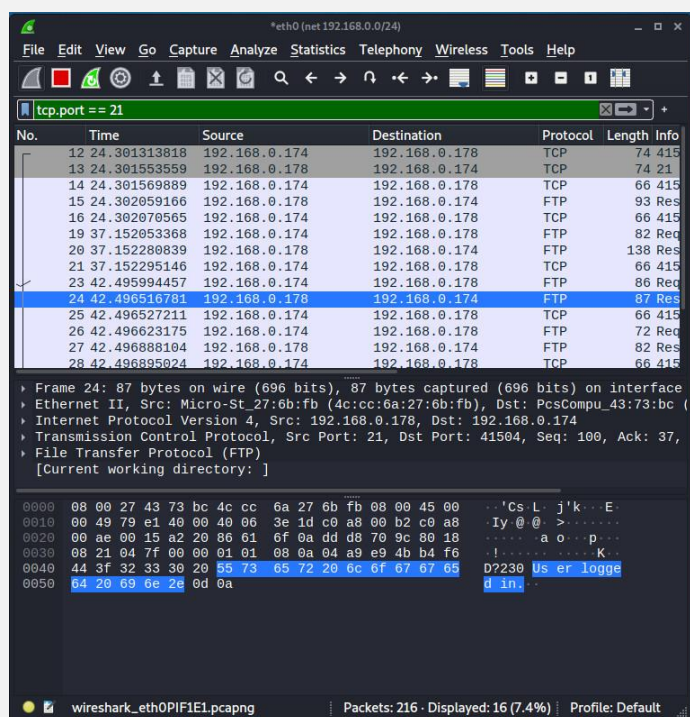
Фильтры отображения

Теперь, когда Wireshark перехватывает весь трафик в нашей локальной сети, мы можем войти на FTP-сервер и просмотреть трафик:

```
kali@kali:~$ ftp 192.168.0.174
Name (192.168.0.174:kali): anonymous
Password: passworfbgdbf
ftp> quit
```

Чтобы еще больше сузить фоновый трафик, давайте воспользуемся фильтром отображения, чтобы сосредоточиться только на протоколе FTP. Фильтры отображения гораздо более гибкие, чем фильтры захвата, и имеют немного другой синтаксис. Фильтры отображения, как следует из названия, фильтруют только отображаемые пакеты, в то время как Wireshark продолжает перехватывать весь сетевой трафик для диапазона адресов

192.168.0.0/24 в фоновом режиме. Поэтому можно очистить фильтр без перезапуска захвата. Давайте применим фильтр отображения, который будет отображать только данные FTP (TCP трафик на порту 21):

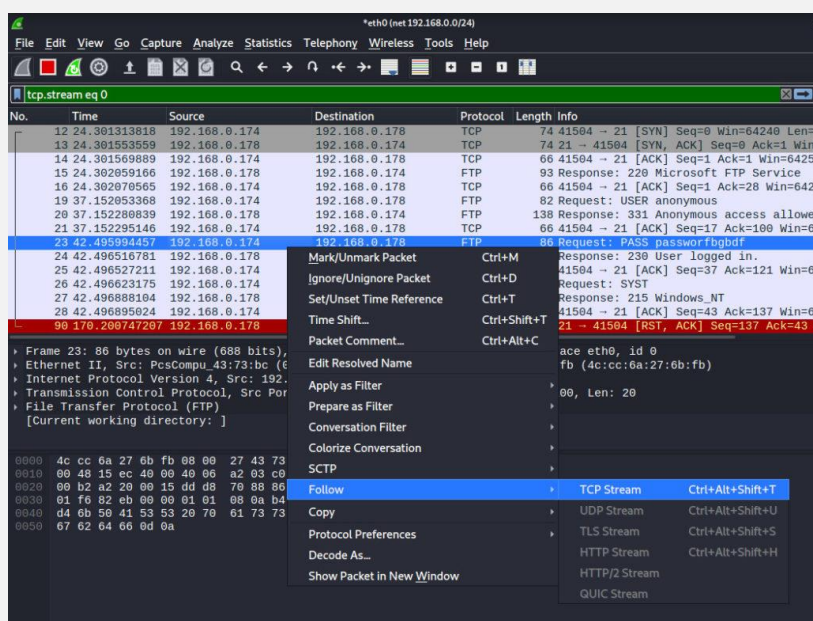


Теперь мы можем видеть только FTP трафик на порту 21.

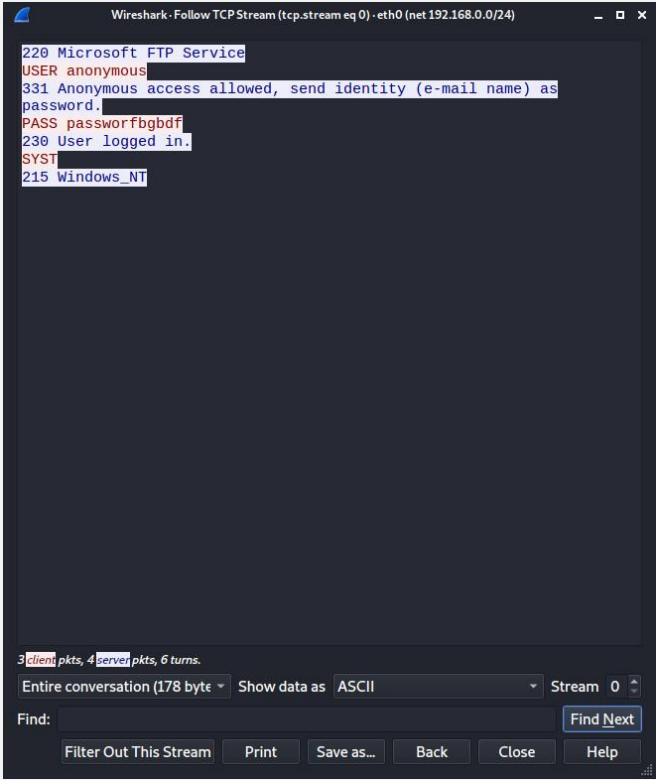
Функция "Follow TCP Stream"

Wireshark позволяет нам просматривать сетевой трафик, включая содержимое каждого пакета. Однако нас больше интересуют потоки данных между различными приложениями. Мы можем использовать способность

Wireshark собирать определенный сеанс и отображать его в различных форматах. Чтобы просмотреть конкретный поток TCP, мы можем щелкнуть правой кнопкой мыши на интересующем нас пакете, например, на пакете, содержащем команду USER в нашем сеансе FTP, затем выбрать **Follow > TCP Stream**:



Собранный поток TCP гораздо легче читать, и мы можем проанализировать наше взаимодействие с FTP-сервером. Поскольку FTP – это протокол с "открытым текстом", мы можем видеть команды и выходные данные, отправленные и полученные нашим FTP-клиентом:



The image shows a Wireshark window titled "Follow TCP Stream (tcp.stream eq 0) - eth0 (net 192.168.0.0/24)". The main pane displays the text of the selected TCP stream, which is an FTP session. The text is color-coded: client commands are in red and server responses are in blue. The session starts with a "220 Microsoft FTP Service" message, followed by a "USER anonymous" command and a "331 Anonymous access allowed, send identity (e-mail name) as password." response. Then, a "PASS passworfbgdbf" command is sent, followed by a "230 User logged in." response. The session continues with "SYST" and "215 Windows_NT" messages. At the bottom, a summary bar indicates "3 client pkts, 4 server pkts, 6 turns." and "Entire conversation (178 bytes)". Below this are buttons for "Find Next", "Filter Out This Stream", "Print", "Save as...", "Back", "Close", and "Help".

```
220 Microsoft FTP Service
USER anonymous
331 Anonymous access allowed, send identity (e-mail name) as
password.
PASS passworfbgdbf
230 User logged in.
SYST
215 Windows_NT
```

Команды, используемые в уроке:

```
kali@kali:~$ ftp 192.168.0.174
```